

Cortex KSPM Documentation - Detailed

1. Kubernetes security

2. KSPM limitations and system components

- note The CPU and memory limits can be adjusted to align with your resource needs. For configuration steps, refer to Configure Kubernetes Connector resource limits.
- note Windows and Unix are not supported.
- 2.1. Configure Kubernetes Connector resource limits

3. Supported Kubernetes distributions

- note Does not include Autopilot.
- note In Google Container-Optimized OS release 100 and earlier, where the FANOTIFY EXEC flag is not supported, the Kernel configuration may be partial for the user mode agent to properly function. In such cases, the agent will fallback to asynchronous mode. In RHCOS version 4.12 and earlier, the Kernel configuration may be partial for the user mode agent to..

4. Onboard the Kubernetes Connector

- note This option is not supported for Fargate.
- note Enabling Realtime Protection installs the agent on your Kubernetes clusters as a DaemonSet.
- note Duplicate keys are not allowed.
- note For Fargate, you must provide the cluster resource identifier. The format of the identifier is `arn:aws:eks:region:account-id:cluster/cluster-name`.
- note Basic authentication is only supported in Posture Management. If deploying Realtime Protection, select None.
- note If you install the latest version but select the N-1 strategy, this policy will take effect starting from the next upgrade cycle (it will not immediately downgrade your current installation). If you choose an older version and keep the latest strategy, the latest version will be installed.

4.1. OpenShift container registry

4.2.1. Repository architecture and tenant management

- note Make sure to disable auto upgrade, so it does not conflict with Flux or ArgoCD state management.
- note If the namespace provided in the tenant is different from `parw`, change the namespace in both the Kustomization and HelmRelease files.

4.2.2. Deploy with Flux CD

4.2.3. Deploy with ArgoCD

4.2.4. Private registry support

4.2.5. GitOps lifecycle management

4.2.6. Troubleshooting GitOps deployments

- note For Proof of Concept testing, the repository includes a `deploy-gitlabsh` script to deploy a self-hosted GitLab EE server directly on your cluster.

5. KSPM dashboard

- imp... Users can access all information on the dashboard when their user access is scoped to view All assets or assigned to the Instance Administrator role. Otherwise, users with granular scoping set to No assets or Select asset groups will have limited access to the dashboard. For more information on Scope-Based Access Control (SBAC), see Manage user scope..
- navi... To access the KSPM dashboard, select Dashboards & Reports → Dashboard or Modules → Kubernetes Security → KSPM Dashboard

6. KSPM Graph

- 6.1. Asset detail card
 - note Workloads context. The workloads section specifically identifies managed workloads, including Deployments, DaemonSets, StatefulSets, CronJobs, and ReplicaSets not managed by deployments, and jobs not managed by a CronJob.
- 6.2. Security finding categories

7. Kubernetes Clusters

- note Data for the Resource Explorer and Vulnerabilities tabs are populated with data once the posture management solution is deployed.

8. Kubernetes Resources Inventory

9. Manage Kubernetes Connector instances

- note After uninstalling the Kubernetes connector, the connector status updates to Not connected 48 hours after the uninstall process is initiated.

10. Run an on-demand Kubernetes cluster scan

- note If the Kubernetes connector for the target cluster sent a heartbeat more than 15 minutes ago, the Kubernetes Cluster Scan Now dialog displays the message: Action temporarily unavailable. The connector connectivity cannot currently be verified.
- note If the connector version is earlier than 2.0, the Request scan option appears as Request scan (Update required) and is disabled. Upgrade the Kubernetes connector to version 2.0 or later to enable on-demand scanning.
- imp... The nodes and containers scan is both CPU and memory-intensive. Run the scan no more than once every six hours to avoid performance degradation on the target cluster.

12. Create prevent policy for Kubernetes clusters

- prer... Ensure that the Kubernetes Connector is installed for this Kubernetes cluster and that admission controller enforcement is enabled.
- note If there are no rules listed, check that the cloud workload rule and policy were correctly configured and applied in Cortex Cloud.

- prer... Users need View/Edit RBAC permissions (under Policies → Compute Policies) or the Instance Administrator role to view, edit, and modify Cloud Workload Policies policies.

- imp... Users with SBAC granular scoping (in addition to the RBAC permissions required for Cloud Workload Policies) can only view Cloud Workload Policies, when their access is scoped to any of the available options: All assets, No assets, or Select asset groups. For more information on granular scoping, see Manage user scope. When no SBAC restriction is..

11.1. How policies and rules work together

- note Issues are automatically resolved when the finding is no longer applicable to the asset or when the affected asset is removed from the inventory. For more details on Prevent and create issues, see Cloud Workload Preventive Action.

11.2.1. Types of Cloud Workload Policies

11.2.1.1. Trusted image cloud workload policies

- note Registry scanning is for finding problems that are objectively issues regardless of context, organization, or scope. Trust, however, is subjective. Depending on the scope and other factors, an issue may or may not be problematic, and can change over time depending on the context.
- note Trusted image policies do not override other policies and their rules, such as malware policies, misconfiguration policies, and secrets policies.
- caut... The default behavior for the prevent action when trust criteria are unavailable is Create an issue. Be aware that changing this default will mean an incomplete deployment file can block a workload.

11.2.2. Cloud Workload Policies page

11.2.2.1. Show or hide the widget panel

11.2.2.2. Change the layout of the policies table

11.2.2.3. Policy Details Panel

11.2.3. Enable or disable a Cloud Workload Policy

Posture Management → Rules & Policies → Policies → Cloud Workload

The Evaluation stage for Misconfiguration policies is supported only in the Runtime SDLC stage and is enforceable through the Kubernetes Admission Controller for clusters on-boarded using the Posture Management (KSPM) Connector.

Use Create a new Custom Detection Rule to define and add new custom rules as required.

Each rule may support different actions. While some include both Create an issue and Prevent and Create an issue, others provide only the Create an issue option.

All non-relevant (non-compute) assets are automatically excluded from the included asset list.

Currently, dynamic asset groups for Kubernetes Prevent Policies support only the following attributes: Kubernetes Resource Cluster: The cloud identifier for the cluster. Kubernetes Resource Namespace: The namespace where the resource is located. Kubernetes Resource Labels: The labels assigned to the resource. Kubernetes Resource Category: The category..

See Cloud Workload Preventive Action, to learn more about the Prevent action behavior and prerequisites.

If the Prevent and create an issue action is selected, the preventive actions in the CI pipeline will trigger a Fail Pipeline by returning an exit code of 2 in the CI tool.

Choosing this option results in the automatic selection of all other asset scopes in the list.

See Cloud Workload Preventive Action, to learn more about the Prevent action behavior and prerequisites.

See Cloud Workload Preventive Action, to learn more about the Prevent action behavior and prerequisites.

Choosing this option results in the automatic selection of all other asset scopes in the list.

See Cloud Workload Preventive Action, to learn more about the Prevent action behavior and prerequisites.

11.2.4. Create a Cloud Workload Policy

11.2.5. Use an existing policy to create a new Cloud Workload policy

11.2.6. Edit a Cloud Workload Policy

11.2.7. Delete a Cloud Workload Policy

11.2.8. Cloud Workload Preventive Action

11.3.1. Default (pre-defined) Rules

11.3.2. Custom (user-defined) Rules

11.3.3. Cloud Workload Rules page

- note Keep the following caveats in my mind when working with Rules. Instance Administrators are able to view all facets of Rules without restrictions, even if Scope Based Access Control (SBAC) roles are in effect. Learn more about SBACManage user scope. If you've been assigned a custom role with View/Edit permissions limited by SBAC, you may not be able..

11.3.3.1. Filter page results

11.3.3.2. Change the layout of the rules table

11.3.3.3. Rule details panel

11.3.4. Create a new Custom Detection Rule

The custom rule must use the match term (not deny or others) to function properly.

Only users with the following roles can enable or disable Custom Code Execution: Account Admin Instance Administrator Deployment Admin Privileged Security Admin

Only Custom Detection Rules (not built-in rules) can be assigned to custom controls.

The custom Python scripts are intended to be executed exclusively for compliance checks and validations. To ensure the scripts are used properly and no security risks or unintended changes occur, the system implements the following restrictions and safeguards: Only a predefined set of Python libraries and functions required for compliance checks are..

11.3.5. Use an existing rule to create a new Custom Detection Rule

11.3.6. Edit a Custom Detection Rule

11.3.7. Delete a Custom Detection Rule